



INFORME DE EVALUACIÓN DE SEGURIDAD

Security Assessment

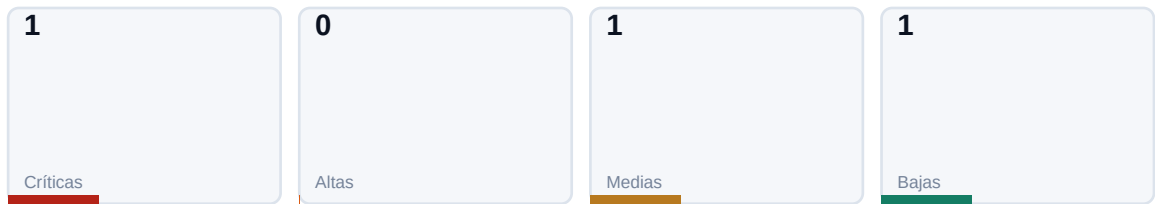
Informe técnico y ejecutivo de pruebas de seguridad autorizadas, con evidencia, priorización y recomendaciones de remediación.

OBJETIVO	portal.interno.local
RIESGO GLOBAL	CRÍTICO
FECHA DE EVALUACIÓN	2026-07-24 14:30:00
IDENTIFICADOR	PT-20260724-0042

Clasificación: Confidencial. Este documento contiene información técnica sensible y debe compartirse únicamente con personal autorizado.

Resumen ejecutivo

La evaluación identificó una debilidad crítica de control de acceso y configuraciones de transporte mejorables. Se recomienda contener la exposición crítica de inmediato y completar un re-test.



HALLAZGOS	CRÍTICOS + ALTOS	REMEDIACIONES	ESTADO
3	1	3	COMPLETED

Alcance y metodología

El alcance registrado para esta ejecución fue **portal.interno.local**. La evaluación combina reconocimiento automatizado, análisis asistido por IA y validaciones técnicas registradas por la plataforma. Los resultados representan una observación puntual del activo en la fecha indicada.

La estructura del informe toma como referencia prácticas de OWASP WSTG, NIST SP 800-115 y PTES: separación entre resumen ejecutivo y detalle técnico, evidencia reproducible, limitaciones y recomendaciones priorizadas. Las etiquetas de severidad son cualitativas; no constituyen una puntuación CVSS v4.0 salvo que se incluya un vector explícito.

Criterios y limitaciones

Las pruebas dependen de la conectividad, credenciales, herramientas disponibles y respuestas del objetivo. Un puerto filtrado, un timeout o la ausencia de respuesta se considera inconcluso y no demuestra por sí solo la existencia ni la ausencia de una vulnerabilidad.

Resumen de hallazgos

REF.	HALLAZGO	SEVERIDAD	ACTIVO / SERVICIO
F-01	Control de acceso insuficiente	CRÍTICO	https / 443
F-02	Política HSTS ausente	MEDIO	https / 443
F-03	Divulgación de versión del servidor	BAJO	http / 80

Hallazgos detallados

F-01Control de acceso insuficiente		CRÍTICO
PUERTO	SERVICIO	REFERENCIA
443	https	F-01

Descripción y evidencia

Un usuario de bajo privilegio pudo consultar recursos administrativos mediante una referencia directa.

Recomendación

Aplicar autorización por objeto en el servidor, negar por defecto y agregar pruebas de regresión.

F-02Política HSTS ausente		MEDIO
PUERTO	SERVICIO	REFERENCIA
443	https	F-02

Descripción y evidencia

La respuesta HTTPS no incluyó Strict-Transport-Security.

Recomendación

Habilitar HSTS con una vigencia gradual y validar primero todos los subdominios.

F-03Divulgación de versión del servidor		BAJO
PUERTO	SERVICIO	REFERENCIA
80	http	F-03

Descripción y evidencia

La cabecera Server expuso información de versión útil para reconocimiento.

Recomendación

Eliminar tokens de versión de cabeceras y páginas de error.

Plan de remediación

PRIORIDAD	ACCIÓN	PROPIETARIO SUGERIDO
Inmediata	Aplicar autorización por objeto en el servidor, negar por defecto y agregar pruebas de regresión.	Equipo responsable del activo
30 días	Habilitar HSTS con una vigencia gradual y validar primero todos los subdominios.	Equipo responsable del activo
Próximo ciclo	Eliminar tokens de versión de cabeceras y páginas de error.	Equipo responsable del activo

Validación recomendada

Después de aplicar las correcciones, realizar un re-test focalizado con el mismo alcance, conservar evidencia de cierre y actualizar el estado de cada hallazgo. Los cambios de infraestructura o exposición deben evaluarse nuevamente.

Anexo A - Explotación y validación

EXPLOIT	HERRAMIENTA	RESULTADO
Validación controlada de acceso	HTTP	Confirmado en entorno autorizado

Anexo B - Evidencia de comandos

Comando: 2026-07-24 14:04:00

```
curl -I https://portal.interno.local
```

```
HTTP/2 200
```

```
server: nginx
```

```
content-type: text/html
```

Referencias y notas

OWASP Web Security Testing Guide (WSTG)

Referencia para estructura de pruebas web, evidencia y comunicación de hallazgos.

NIST SP 800-115

Guía técnica para planificar pruebas, analizar hallazgos y desarrollar estrategias de mitigación.

Penetration Testing Execution Standard (PTES)

Referencia para separar resumen ejecutivo, informe técnico, alcance, impacto y remediación.

CVSS v4.0 - FIRST

Las etiquetas cualitativas del informe son orientativas. Para declarar conformidad CVSS se requiere calcular y conservar el vector completo, además del contexto de amenaza y entorno cuando corresponda.

Este informe es una evaluación puntual y no garantiza la identificación de todas las vulnerabilidades. Debe interpretarse junto con el contexto operativo y de negocio del activo.